Риски и валидация требований

Высокоуровневые риски

ID	Область	Описание	Основная мера снижения
R1	Технический / операционный	Сценарий или агент может вызвать нежелательное воздействие на корпоративную инфраструктуру	Stage-тестирование, белый и черный списки, безопасное завершение, откат, лимиты и kill switch
R2	Информационная безопасность	Компрометация BAS, утечка артефактов или избыточные права могут привести к компрометации среды	DevSecOps, ограничение прав, защищенные хранилища и каналы, аудит доступа
R3	Технический / интеграционный	Средства защиты могут блокировать агент или иначе мешать штатному выполнению симуляции	Тестирование сопряжения со СЗИ и согласование необходимых исключений для самого агента
R4	Ресурсный / экспертный	Не хватает времени/экспертизы ИБ для подготовки и валидации сценариев	Приоритизация набора сценариев и фиксированные границы Фазы №1
R5	Производительность	Агенты или параллельные кампании могут создать чрезмерную нагрузку	Лимиты CPU/RAM, ограничение параллельных кампаний, нагрузочные тесты
R6	Технический / интеграционный	SIEM/EDR могут не давать нужную телеметрию или интерфейсы для надежной корреляции	Раннее технологическое исследование, минимальный коннектор с правами только на чтение, фиксация ограничений до архитектуры
R7	Организационный / сроки	Задержки согласования сценариев, ROE, доступа к сегментам и эксплуатационных процедур.	Календарь, шаблоны, журнал решений, резервирование тестовых окон
R8	Тестовая среда	Stage может недостаточно соответствовать контролируемому корпоративному сегменту	Эталон конфигурации, максимально близкая среда, прогон, поэтапное развертывание, регрессионное тестирование
R9	Управление требованиями	Добавление новых сценариев, интеграций и функций может размыть границы проекта	Точка отсчета, бэклог и контроль версий, перенос внеплановых требований в следующие фазы

Риски и валидация требований

ID	Приоритет	Валидация	Риск	Связанный риск
BR-01	Критический	Прогон утвержденного сценария на stage/ контролируемом стенде, проверить запуск, выполнение и безопасное завершение	Потеря контроля над сценарием может привести к инциденту или остановке критического сервиса	R1
BR-02	Критический	Контрольный сценарий с заранее известным событием, проверить получение и фиксацию статуса обнаружения/блокировки	Недостаточная телеметрия SIEM/EDR может не позволить надежно оценить реакцию СЗИ	R6
BR-03	Критический	Приемочный прогон по чек-листу Фазы №1	Срыв сроков, неполный набор сценариев или незавершенная приемка	R7
BR-04	Критический	Повторно запустить один утвержденный сценарий по регламенту и сравнить результат без ручной доработки сценария	Изменение среды или версии агента может ухудшить воспроизводимость	R8
BR-05	Критический	Проверить итоговый отчет и материалы апробации: результаты, ограничения и рекомендации для решения о следующей фазе	Неполные результаты пилота могут не дать надежной основы для решения о дальнейшем развитии	R9
UR-01	Критический	Проверить доступ каждой роли к разрешенным и запрещенным операциям	Ошибки RBAC могут дать лишние привилегии	R2

UR-02	Критический	Проверить наличие всех 5 ролей и корректность назначения ролей тестовым пользователям	Неверная модель ролей может нарушить разделение обязанностей	R2
UR-03	Критический	Проверить вход с MFA на тестовых учетных записях, отказ при отсутствии второго фактора	Ошибки MFA или интеграции с IdP могут заблокировать доступ	R2
UR-04	Критический	Матрица прав + позитивные/негативные тесты на доступ к функциям и данным	Неверная авторизация может открыть доступ к опасным операциям или данным	R2
UR-05	Критический	Выполнить набор тестовых действий и проверить наличие записей в журнале аудита	Неполный/изменяемый аудит осложнит расследование	R2
UR-06	Высокий	Проверить документированный процесс выдачи, изменения и отзыва доступа на тестовом кейсе	Отсутствие формального процесса доступа создаст риск несанкционированных полномочий	R7
AG-01	Критический	Зарегистрировать тестовый агент и проверить появление его записи в платформе	Неудачная регистрация усложнит подключение инфраструктуры	R7
AG-02	Критический	Подключить валидный и невалидный агент, проверить успешную/отклоненную аутентификацию	Компрометация учетных данных агента может дать несанкционированный доступ	R2
AG-03	Критический	Отключить/восстановить тестовый агент и проверить отображение состояния и доступности	Некорректный статус может привести к запуску по недоступной цели	R3
AG-04	Высокий	Выполнить контролируемое отключение и убедиться, что новые действия с агентом не запускаются	Сбой отключения может оставить агент управляемым или конфликтующим с СЗИ	R3
AG-05	Высокий	Удалить тестовый агент и проверить удаление без остаточных активных связей/учетных данных	Не полностью удаленный агент оставит остаточные артефакты/доступ	R1
AG-06	Высокий	Установить обновление на stage и проверить переход между версиями без потери управляемости	Неуспешное обновление может вывести агент из строя	R8
AG-07	Высокий	Проверить отображение уникальной/однозначной версии агента в реестре	Неоднозначная версия усложнит откат и расследование	R2
AG-08	Критический	До обновления провести stage-тест, запуск обновления в контролируемом контуре разрешить только после успешного результата	Обновление без stage-проверки может привести к отказу агентов в контролируемом контуре	R8
AG-09	Высокий	Установить обновление и выполнить тест отката на предыдущую версию	Ошибка отката может потребовать ручного восстановления агента	R8
AG-10	Критический	Проверить права процесса агента на Windows и Linux и отсутствие лишних привилегий	Избыточные права увеличивают последствия компрометации агента	R1
AG-11	Критический	Нагрузочный тест штатного сценария, подтвердить пиковое CPU не выше 5%	Высокая нагрузка может вызвать деградацию целевых хостов	R5
AG-12	Высокий	Нагрузочный тест штатного сценария, подтвердить RAM не выше 100 МБ в пике	Превышение RAM может привести к деградации целевых хостов	R5
SC-01	Критический	Создать, открыть и найти сценарий в централизованном репозитории	Отказ репозитория сделает сценарии недоступными	R6
SC-02	Критический	Создать тестовый сценарий пользователем с разрешенной ролью, проверить запрет для других ролей	Ошибка прав может позволить неподготовленному пользователю создавать сценарии	R2
SC-03	Критический	Создать два сценария и проверить уникальность идентификаторов	Дубли идентификаторов нарушат трассируемость результатов	R2
SC-04	Критический	Проверить карточку сценария и наличие выбранного вектора атаки	Неверная классификация осложнит анализ покрытия	R4

SC-05	Критический	Проверить наличие и корректность MITRE ATT&CK маппинга для утвержденного сценария	Ошибка маппинга приведет к некорректной аналитике и отчетности	R4
SC-06	Критический	Открыть карточку утвержденного сценария и сверить ожидаемый результат	Неопределенный ожидаемый результат делает приемку неоднозначной	R4
SC-07	Критический	Создать новую версию сценария и проверить хранение предыдущей версии	Потеря истории версий осложнит откат и расследование	R9
SC-08	Высокий	Проверить отображение текущей версии и статуса сценария	Неясный статус может привести к запуску неподготовленной версии	R9
SC-09	Критический	Изменить тестовый сценарий, провести stage-тест и проверить блокировку эксплуатации до успешной проверки	Изменение без теста может создать небезопасный сценарий	R1
SC-10	Критический	Загрузить/создать не менее 6 утвержденных сценариев и проверить их количество	Недостижение 6 сценариев сорвет критерии Фазы №1	R4
SC-11	Критический	Проверить состав шести сценариев: 2 фишинг, 2 сетевые атаки, 2 имитация распространения ВПО	Нарушение распределения по трем векторами приведет к неполному покрытию приемки	R4
TG-01	Критический	Запустить только утвержденный сценарий и проверить корректный выбор из библиотеки	Ошибка фильтрации может допустить запуск по запрещенной цели	R1
TG-02	Критический	Выбрать тестовую цель и проверить ее корректное попадание в кампанию	Неверный выбор цели создает риск выполнения сценария не на том хосте	R1
TG-03	Критический	Добавить цель из черного списка и убедиться, что запуск блокируется	Ошибка в черном списке может затронуть критический сегмент	R1
TG-04	Критический	Добавить разрешенную цель в белый список и проверить прохождение проверки допуска	Ошибка в белом списке может либо заблокировать тест, либо допустить неразрешенную цель	R1
TG-05	Критический	Проверить, что критический сегмент из черного списка недоступен для запуска	Неверный черный список критических сегментов имеет высокий ущерб при ошибке	R1
TG-06	Критический	Перед запуском выбрать допустимую и недопустимую цель, проверить результат предварительной проверки	Ошибки предварительной проверки могут пропустить неподготовленную среду	R1
TG-07	Критический	Проверить каждый согласованный параметр запуска после его фиксации в ТЗ	Неуточненные параметры запуска создают неоднозначность приемки	R9
TG-08	Высокий	Создать несколько кампаний и проверить уникальность ID кампании	Дубли ID кампании ухудшат трассируемость	R6
TG-09	Критический	Задать ограничение времени и проверить остановку/перевод в безопасное состояние при его достижении	Отсутствие тайм-лимита повышает риск неконтролируемого выполнения	R1
TG-10	Критический	Попытаться превысить лимит параллельных кампаний и проверить блокировку нового запуска	Слишком высокий параллелизм повышает нагрузку и риск инцидента	R5
TG-11	Критический	Запустить кампанию без подтверждения/с подтверждением и проверить корректность обоих сценариев	Отсутствие явного подтверждения повышает риск случайного запуска	R1
EX-01	Критический	Нажать аварийную остановку на stage и проверить прекращение активных действий	Неработающая аварийная остановка может привести к инциденту	R1
EX-02	Критический	Проверить kill switch как отдельный аварийный механизм и запрет новых действий	Kill switch не сработает или будет недоступен в аварийной ситуации	R1
EX-03	Критический	Попробовать выполнить действие из запрещенного перечня и проверить блокировку	Запрещенное действие может повредить целевой системе	R1

EX-04	Критический	Проверить сетевое соединение между сервером/прокси/агентом на шифрование в согласованной тестовой конфигурации	Компрометация канала может дать возможность вмешательства в управление	R2
EX-05	Критический	Проверить взаимную аутентификацию компонентов на валидных/невалидных сертификатах	Отсутствие взаимной аутентификации повышает риск подмены компонента	R2
EX-06	Критический	Остановить/эмулировать недоступность сервера и проверить блокировку новых запусков	Недоступность сервера не должна оставлять возможность неконтролируемых новых запусков	R1
EX-07	Критический	Оборвать связь тестового агента во время кампании и проверить переход в безопасное состояние	Потеря связи может оставить сценарий в неопределенном состоянии	R1
EX-08	Критический	Выполнить сценарий с тестовыми артефактами и проверить автоматическую очистку	Остаточные артефакты могут повлиять на целевой хост	R1
EX-09	Критический	Для каждого утвержденного сценария выполнить предусмотренный откат на stage	Отсутствие отката сделает часть сценариев неприемлемыми для контролируемого контура	R1
EX-10	Критический	Подтвердить тестами откат для 100% сценариев релизного набора	Непроверенный откат создает ложное ощущение безопасности	R1
EX-11	Критический	После отката выполнить контрольные проверки восстановления состояния	Неподтвержденное восстановление может скрыть остаточные изменения	R1
EX-12	Критический	Создать тестовый инцидент и проверить блокировку последующих симуляций до разрешения	Продолжение работ после инцидента увеличивает потенциальный ущерб	R1
EX-13	Высокий	Проверить выполнение симуляции по согласованному расписанию	Ошибка в расписании или не следование согласованному расписанию может привести к инциденту	R9
OR-01	Критический	Запустить утвержденный сценарий из UI	UI-запуск может инициировать сценарий без необходимых предварительных проверок	R1
OR-02	Критический	Выполнить немедленный ручной запуск и проверить старт кампании	Ошибка ручного запуска может привести к некорректным параметрам кампании	R1
OR-03	Высокий	Создать расписание и проверить автоматический старт в заданное время	Ошибка планировщика может запустить сценарий вне согласованного окна	R7
OR-04	Критический	Проверить выполнение тестового сценария по отдельным этапам с управляемыми переходами	Неконтролируемая последовательность этапов повышает риск инцидента	R1
OR-05	Критический	Во время кампании проверить отображение текущего статуса	Неверный статус усложнит оперативный контроль	R1
OR-06	Критический	Проверить статусы этапов/сценариев до, во время и после выполнения	Потеря статуса этапа не даст оператору понять текущее состояние	R1
OR-07	Критический	Создать контролируемую ошибку и проверить ее фиксацию	Неполная фиксация ошибок затруднит расследование	R6
OR-08	Критический	Завершить кампанию штатно и проверить итоговый статус/очистку	Неправильное завершение может оставить активные артефакты	R1
OR-09	Высокий	Выполнить кампанию, сохранить ее, повторить и проверить наличие истории	Потеря истории сделает сравнение и воспроизводимость невозможными	R9
MON-01	Критический	Остановить/восстановить тестовый сервер и проверить отображение доступности сервера	Ложный статус сервера может скрыть отказ	R1
MON-02	Критический	Подключить/отключить тестовый агент и проверить доступность	Ложный статус агента может привести к запуску по недоступной цели	R1

MON-03	Критический	Провести кампанию и проверить статусы кампании и сценариев	Неполный статус кампании усложнит контроль	R6
MON-04	Критический	Создать тестовую ошибку и проверить ее появление в мониторинге	Неотображаемые ошибки задержат реакцию	R6
MON-05	Критический	Сгенерировать тестовое критическое событие и проверить его отображение	Пропуск критических событий увеличит время реакции	R1
MON-06	Высокий	Провести сценарий и проверить, что оператор может определить состояние без открытия техлогов	Слишком технический UI повышает вероятность неверной интерпретации состояния	R6
INT-01	Критический	Подключить MaxPatrol SIEM в stage и получить тестовую телеметрию	Выбранный SIEM может не предоставить нужную телеметрию	R6
INT-02	Критический	Подключить MaxPatrol EDR в stage и получить тестовую телеметрию	Выбранный EDR может не предоставить нужную телеметрию	R6
INT-03	Критический	Проверить, что версия 0.1 использует согласованные MaxPatrol SIEM/EDR как базовый интеграционный контур	Изменение целевых продуктов после фиксации допущения увеличит границы	R9
INT-04	Критический	Получить согласованный минимальный набор данных из SIEM/EDR для тестовой кампании	Недостаток данных сделает результат неопределенным	R6
INT-05	Критический	Провести сценарий с известным результатом и проверить фиксацию обнаружения/блокировки/неопределенности	Ошибка классификации обнаружения/блокировки даст некорректный результат	R6
INT-06	Критический	Сопоставить действия сценария с событиями СЗИ по ID кампании/времени и проверить корректность корреляции	Ошибочная корреляция приведет к ложным выводам об эффективности СЗИ	R6
INT-07	Критический	Провести техническое исследование и зафиксировать API-методы, поля, лимиты и ограничения до разработки промышленного коннектора	API/лимиты могут сделать промышленную интеграцию сложнее запланированного	R6
INT-08	Критический	Проверить права сервисной учетной записи на права "только чтение", операции и отсутствие возможности изменять/удалять исходные события	Избыточные права BAS могут позволить изменение/удаление данных СЗИ	R2
REP-01	Критический	Завершить тестовую кампанию и проверить наличие сводного результата сценария	Неполный результат не позволит принимать сценарий	R6
REP-02	Критический	Проверить просмотр результатов по каждому этапу	Недостаточная детализация этапов усложнит анализ	R6
REP-03	Критический	Провести сценарий с несколькими действиями и проверить пройдено/провалено для каждого	Потеря статуса пройдено/провалено отдельных действий скроет проблемные шаги	R6
REP-04	Критический	Открыть дашборд и проверить отображение ключевых результатов	Неверный дашборд может привести к неправильной интерпретации	R6
REP-05	Критический	Провести кампанию и проверить статусы на дашборде	Неактуальные статусы снижают оперативную ценность	R6
REP-06	Критический	Получить телеметрию СЗИ и проверить отображение результатов валидации	Неполная телеметрия может привести к неверной интерпретации	R6
REP-07	Критический	Сформировать отчет по завершенной кампании и проверить обязательные разделы	Неполный отчет затруднит приемку и переход к следующей фазе	R6
REP-08	Высокий	Сохранить результат, повторить кампанию и проверить наличие исходного результата для сравнения	Потеря истории разрушит повторяемость и анализ	R9

REP-09	Высокий	Сравнить два запуска одного сценария в сопоставимых условиях и проверить вывод сравнения	Несопоставимые условия могут сделать сравнение недостоверным	R8
DAT-01	Критический	Выполнить набор операций разных ролей и проверить запись каждой операции в логи аудита	Пропуски аудита усложнят расследование	R2
DAT-02	Критический	Попробовать изменить/удалить аудит-запись через интерфейс и проверить запрет	Изменяемые логи аудита снижают доказательность расследования	R2
DAT-03	Критический	Проверить защищенное хранение сценариев/ артефактов и контроль доступа к хранилищу	Утечка сценариев/артефактов может привести к компрометации	R2
DAT-04	Критический	Проверить матрицу доступа к данным и артефактам позитивными/негативными тестами	Неверные права откроют доступ к чувствительным данным	R2
DAT-05	Высокий	Создать данные и проверить хранение результатов не менее 180 дней и аудит не менее 365 дней либо по более строгому корпоративному сроку	Недостаточный срок хранения может привести к потере истории	R11
DAT-06	Высокий	Выполнить тест резервного копирования/ восстановления и измерить RPO/RTO относительно целей 24 ч/4 ч	Неуспешное резервное копирование/ восстановление приведет к потере результатов/ настроек	R11
NFR-01	Критический	Нагрузочный тест агента на типовом сценарии и измерение CPU, подтвердить пик ≤ 5%	Превышение CPU может деградировать целевые хосты	R5
NFR-02	Высокий	Нагрузочный тест агента и контроль пикового RAM ≤ 100 МБ	Превышение RAM может деградировать целевые хосты	R5
NFR-03	Высокий	Запустить до 5 параллельных кампаний и проверить отсутствие нарушения согласованных ограничений	Высокий параллелизм увеличит нагрузку и риск инцидента	R5
NFR-04	Высокий	Нагрузочный тест UI при штатной нагрузке, проверить, что 95% стандартных операций выполняются ≤ 3 с	Медленный UI может привести к ошибкам оператора	R5
NFR-05	Критический	Разорвать тестовое соединение сервера/агента и проверить, что новые неконтролируемые действия не запускаются	Потеря связи может оставить активность в небезопасном состоянии	R1
NFR-06	Критический	Искусственно вызвать отказ критического компонента на stage и проверить переход в безопасное состояние	Необработанный отказ критического компонента увеличит последствия сбоя	R1
NFR-07	Критический	Провести сценарий в контролируемом сегменте и убедиться, что критические корпоративные сервисы остаются доступными	Сбой критического сервиса будет прямым нарушением критерия приемки	R1
NFR-08	Критический	Проверить деплой и сетевую схему: все компоненты находятся в согласованном корпоративном контуре	Выход за корпоративный контур создаст риски безопасности и нарушения ограничений	R2
NFR-09	Критический	Проверить расположение репозиториев, среды и артефактов, исключить публичное облако из цепочки Фазы №1	Публичное облако нарушит прямое ограничение Фазы №1	R2
NFR-10	Критический	Проверить шифрование и защищенный транспорт между ключевыми компонентами	Слабая защита каналов допускает перехват/ подмену	R2
NFR-11	Критический	Проверить RBAC на UI/API и негативными тестами недоступность запрещенных операций	Ошибки RBAC могут дать несанкционированный доступ	R2
NFR-12	Критический	Проверить MFA для всех пользовательских ролей	Отсутствие MFA повышает риск компрометации учетной записи	R2
NFR-13	Высокий	Добавить тестовый новый сценарий без изменения ядра	Жесткая архитектура увеличит стоимость добавления новых сценариев	R9

NFR-14	Высокий	Добавить тестовый интеграционный модуль	Жесткая интеграционная модель увеличит стоимость новых коннекторов	R9
NFR-15	Высокий	Провести ревью архитектуры и проверить, что решение не закрывает возможность будущей мультиарендности	Неучет будущей мультиарендности может привести к дорогостоящей переработке архитектуры на следующих фазах	R9
QA-01	Критический	Проверить выполнение обязательного stage-теста до допуска сценария	Переход к контролируемому контуру без stage может привести к инциденту	R8
QA-02	Критический	Для каждого сценария выполнить stage-тест и проверить наличие положительного результата перед контролируемым запуском	Непроверенный сценарий может вести себя иначе в корпоративном сегменте	R8
QA-03	Критический	Сверить список сценариев Фазы №1 и результаты тестов отката, покрытие должно быть 100%	Непроверенный откат делает безопасное выполнение недоказанным	R1
QA-04	Критический	Провести внутреннюю апробацию и проверить журнал инцидентов, целевое значение 0 критических инцидентов, вызванных платформой	Инцидент остановит дальнейшие симуляции и сдвинет сроки	R1
QA-05	Критический	Провести апробацию на согласованном наборе сервисов и проверить отсутствие критической недоступности	Недоступность критического сервиса приведет к неприемлемому результату пилота	R1
QA-06	Критический	Перед передачей выполнить ревью дефектов, критические и блокирующие дефекты в ядре не допускаются	Критические дефекты могут сделать релиз непригодным к эксплуатации	R9
QA-07	Критический	Проверить наличие функциональных и нагрузочных тестов и их успешное прохождение	Неполный тестовый контур оставит дефекты необнаруженными	R5
QA-08	Критический	Проверить воспроизводимость выполнения утвержденных сценариев	Невоспроизводимость сценариев сдвинет сроки и не покроет критерии приемки	R9
DOC-01	Критический	Проверить комплект технической документации по чек-листу приемки	Неполная техдокументация осложнит передачу и сопровождение	R7
DOC-02	Критический	Проверить наличие пользовательской инструкции и пройти по ключевым пользовательским сценариям	Слабая пользовательская документация увеличит операционные ошибки	R7
DOC-03	Критический	Развернуть тестовый экземпляр строго по инструкции и проверить воспроизводимость	Неактуальная документация снизит воспроизводимость развертывания	R8
DOC-04	Критический	Настроить тестовый сценарий по инструкции и проверить полноту описания	Неполная документация сценария может привести к небезопасной настройке	R8
DOC-05	Высокий	Провести инструктаж тестовой группы и зафиксировать факт прохождения	Неподготовленные пользователи могут допустить операционные ошибки	R7
DOC-06	Высокий	Проверить наличие назначенного владельца сопровождения	Отсутствие владельца сопровождения приведет к простоям и неопределенности ответственности	R7
DOC-07	Высокий	Проверить наличие назначенного владельца процесса обработки инцидентов	Неопределенный владелец процесса обработки инцидентов замедлит реакцию	R7
DOC-08	Высокий	Проверить наличие назначенного владельца обновления сценариев	Неопределенный владелец обновления сценариев повысит риск неконтролируемых изменений	R9
CON-01	Критический	Проверить календарный план и акт приемки на соответствие датам 17.09.2026-17.09.2027	Сдвиг срока нарушит главную временную границу проекта	R7
CON-02	Критический	Проверить границы отсчета и отсутствие внешнего B2B-пилота в Фазе №1	Расширение границ проекта из-за внешних пилотов размоет Фазу №1	R9

CON-03	Критический	Проверить границы отсчета и отсутствие коммерческих задач	Коммерческие задачи увеличат границы и нагрузку команды.	R9
CON-04	Критический	Проверить отсутствие биллинга в границах	Биллинг добавит несвойственную Фазе №1 функциональность	R9
CON-05	Критический	Проверить отсутствие мультиарендности как эксплуатационной функции Фазы №1	Попытка реализовать мультиарендность сейчас увеличит объем и архитектурный риск	R9
CON-06	Критический	Проверить планы развертывания и тестирования на выполнение внутри корпоративного контура	Выход за корпоративный контур нарушит базовое ограничение безопасности	R2
CON-07	Критический	Проверить план инфраструктуры на отсутствие публичных облачных провайдеров	Публичное облако создаст прямое противоречие с ограничениями Фазы №1	R2
CON-08	Критический	Проверить наличие выделенной изолированной stage-/тестовой среды	Недостаточная изоляция среды повышает риск реального воздействия	R8
CON-09	Критический	Проверить, что детализация Фаз №2-3 не входит в текущую точку отсчета	Детализация следующих фаз преждевременно зафиксирует неопределенные решения	R9